JUDGES Q&A — ENGLISH

Questions & Answers

Prepared answers to the questions judges are most likely to ask, each grounded in the actual MIRQAB code, tests and engineering reports.

TEAM

Bdoor Fahed Alosaimi
Nouf Saleh Altalhi
Alaa Rafa Al Saad

PROJECT

MIRQAB — AI-Powered Security Operations Platform for SMBs

27 September 2026

How to use this document

Each answer states what MIRQAB **actually** does today and ends with a status label. Where a feature is limited, not verified or not deployed, the answer says so plainly. Numbers come from the code or from the test run of 27 September 2026 (38 suites, 421 backend tests, all passing).

How to read the status labels

VERIFIED	Tested and confirmed: by the automated test suite (38 suites, 421 tests, all passing on 27 Sep 2026) and/or by a live test recorded in the team's engineering reports.
VERIFIED IN LAB	Confirmed end-to-end in a controlled, containerized lab. Not tested on physical employee devices.
LIMITED	Implemented and working, with a clearly stated limitation.
NOT VERIFIED	Implemented in code but not tested live.
NOT IMPLEMENTED	Not available in the application.
NOT DEPLOYED	No production deployment exists.
BLOCKED	Cannot be completed because of an external dependency.
PLANNED	A future roadmap item. Not built.
DEMO / SIMULATION	Uses synthetic or public demo data. Not a real environment.

A. Problem and positioning

1. What problem does MIRQAB solve?

SMBs receive raw security alerts but lack the Security Operations Center workflow that turns them into decisions: triage, investigation, a timely response and proof of what was done. MIRQAB provides that workflow. It turns events into correlated, explainable incidents with evidence and MITRE context, gives every HIGH/CRITICAL incident a 5-minute response clock, and performs containment only through an authorized, agent-confirmed and audited action.

2. Why SMBs?

They face the same attacks as large enterprises (phishing, brute force, ransomware, C2) but rarely have a staffed SOC, a security budget for commercial SIEM/SOAR suites, or tolerance for sending internal logs to third parties. MIRQAB is built around open-source telemetry (Wazuh, Suricata), deterministic logic that a small team can understand and audit, and a self-hosted AI direction.

3. Why Wazuh?

Wazuh is a widely used open-source security platform with endpoint agents and a built-in **Active Response** mechanism. It lets MIRQAB both **receive** alerts and **act** on an endpoint without a commercial EDR licence. MIRQAB also has a generic endpoint-control interface, so a different EDR, NAC or firewall provider could be plugged in through the same path.

Status: alert ingestion endpoint VERIFIED · Active Response isolation VERIFIED IN LAB · Manager-side forwarding script NOT VERIFIED · GA version 4.14.7 BLOCKED.

B. AI

4. Why not external AI?

Security logs contain internal hostnames, users, IP addresses and sometimes credentials. Sending them to an external service creates privacy, compliance and dependency risks. Language models can also invent facts, such as a non-existent MITRE technique. MIRQAB therefore disables external AI by default. The existing Anthropic Claude integration is for development comparison only and needs **both** an API key **and** an explicit `ALLOW_EXTERNAL_AI_DEV_ONLY=true` flag.

5. How does the AI architecture work?

- **One provider slot.** At most one AI provider is active at a time and providers are never chained. With none configured (today's state), every AI-eligible task uses a deterministic rule-based fallback.
- **Named "agents".** Incident Agent, IOC/IOA Agent, MITRE Risk Agent and Recommendation Agent are least-privilege wrappers around specific deterministic services. Their decisions are recorded, and none of them can create a response action or reach endpoint control.
- **Guardrails.** Prompt-injection delimiting, strict validation of any AI output (for example, severity values and MITRE IDs are checked against the reference), timeouts, a circuit breaker and a concurrency cap.

Status: architecture VERIFIED by unit tests · no model running at runtime.

6. Is Claude, OpenAI or Gemini used at runtime?

No. None of them is used at runtime, and none is used in the evaluator demo. The Claude integration exists but is disabled by default (dual-gated, development only). OpenAI and Gemini are not integrated at all. The only "OpenAI" reference in the code is that the self-hosted provider speaks the widely used "OpenAI-compatible" request format that local model runtimes expose. NOT USED AT RUNTIME

7. How does the self-hosted AI architecture work?

An administrator points `SELF_HOSTED_AI_URL` and `SELF_HOSTED_AI_MODEL` at a model server inside their own network (for example llama.cpp server, Ollama, vLLM or LocalAI). MIRQAB sends minimized data in the OpenAI-compatible `/v1/chat/completions` format, treats every reply as untrusted text, validates it strictly against the expected schema, and falls back to rules on any failure. The URL and model come only from server configuration, never from a client request.

Status: NOT VERIFIED NOT DEPLOYED. No model has been deployed because the development laptop lacks the hardware to run one safely alongside the stack.

C. Access control

8. How does MIRQAB prevent unauthorized access?

- JWT access tokens (15 minutes) pinned to HS256, and rotating refresh tokens (7 days) whose reuse revokes the whole token family.
- bcrypt password hashing (12 rounds). Identical generic errors for wrong email or password. Login, signup and password reset are limited to 5 requests per minute.
- Role checks, department and organization scoping on every collection query, and object-level guards on incidents, tickets and devices.

- Strict input validation (unknown fields rejected), UUID validation, null-byte rejection. API documentation is disabled in production.

Status: VERIFIED (security Phases 1, 5 and 11, plus unit tests).

9. How does RBAC work?

Role	Scope
`ADMIN`	Whole organization, including user management, policies and settings.
`SECURITY_ANALYST`	Whole organization: investigation and response.
`IT_TECHNICIAN`	Only their own department's incidents, devices, tickets and realtime events.
`EMPLOYEE`	Employee Desktop app only. No SOC dashboard or realtime access.

Security Phase 1 ran 18 live tests (for example, a Finance technician requesting Engineering devices gets 403), and all 18 passed. VERIFIED

10. How is organization isolation implemented?

Every tenant-owned record carries an `organizationId`. Queries are filtered by the user's organization, and a user with no organization gets a guaranteed-empty result (fail-closed). The access guards reject any resource whose organization differs from the user's. Notifications, weekly reports and realtime rooms follow the same rule.

Status: VERIFIED by unit tests · LIMITED: no live test with several organizations is recorded.

D. Response and containment

11. How does device isolation work?

1. An authorized user on an incident they can access clicks *Isolate Endpoint* and confirms that only this endpoint is affected.
2. The server resolves the device from the incident itself. The request body cannot name a device.
3. An `ISOLATE_DEVICE` action is saved as PENDING, and the endpoint-control provider (Wazuh Active Response) is called.
4. The outcome becomes SUCCESS only when the agent's own callback confirms execution. Otherwise it becomes FAILED with the reason. A device is shown as "Isolated" only when a genuine SUCCESS action exists.

Status: VERIFIED IN LAB — 2 of 2 end-to-end isolations on a containerized Linux safe-test agent, in 11–15 seconds.

12. How does Wazuh Active Response work here?

MIRQAB calls the Wazuh Manager API to run a registered Active Response command on the target agent. The agent's `isolate-host` script sets the firewall to block traffic, except a narrow allowance for Wazuh and the MIRQAB callback. It then posts its result to `/devices/endpoint-control/active-response-result`, authenticated with the monitoring API key. MIRQAB never treats the Manager's "dispatched" reply as success on its own. Two script bugs (a hang on standard input and a hostname mismatch) were found and fixed in security Phase 2A.

Status: Linux script VERIFIED IN LAB · Windows script NOT VERIFIED.

13. What happens if isolation fails?

The action is recorded as **FAILED** with the reason (for example "fetch failed"). The failure is shown in red in the incident panel and response log, a "containment result" notification is sent for automated attempts, and the audit log records it. The device is **not** marked isolated, and the analyst can escalate, collect evidence or retry. The screenshots in this package show real FAILED outcomes from the development environment, where the virtual devices have no real endpoint behind them.

14. How is idempotency handled?

- **Acknowledgement:** a repeated "Acknowledge" returns the existing record without a new audit entry.
- **Containment decision:** taken once per incident, inside a per-incident PostgreSQL advisory-lock transaction, with a once-only "window expired" marker. Several scheduler ticks or several backend replicas cannot decide twice.
- **Case IDs:** generated by an atomic per-day counter, so concurrent bursts never share an ID.
- **Correlation:** related events join the existing open case instead of creating duplicates.
- **Setup:** the seed and the demo-data import create items only if they are missing, so each dataset event is imported at most once.

VERIFIED by unit tests.

15. How is audit logging handled?

Every security-relevant action writes an audit record whose actor and target are derived on the server from the authenticated user and the resource, never from the request body. Denied access attempts and failed logins are logged. For failed logins, the recorded email is the *attempted* identity. The audit API is read-only: there are no create, update or delete routes. VERIFIED (security Phase 6).

E. Detection and investigation

16. How are incidents correlated?

A new event is compared with open cases from the last **72 hours**, using the same comparison engine as similar-incident search (technique and tactic, indicators, device, department, time). If the score reaches **65**, the event becomes more evidence on that case. Otherwise it starts a new case with its own Case ID. Resolved or closed cases never receive new evidence. The per-dimension breakdown explains to the analyst *why* events were merged. VERIFIED

17. How does MITRE mapping work?

Deterministic rules match the event text against a curated reference of **12 techniques** (T1566, T1110, T1204, T1059, T1046, T1068, T1053, T1078, T1071, T1105, T1567, T1486). Unmatched events stay `UNCLASSIFIED` rather than guessed. VERIFIED LIMITED coverage.

18. How are IOCs extracted?

By deterministic pattern extraction from the evidence text. IOCs are IP addresses, file hashes, domains, URLs and email addresses, each with a confidence value. IOAs are behaviour patterns: credential dumping, lateral movement, process injection, obfuscated execution and defense evasion. Persistence and C2 patterns are extracted separately. If nothing matches, nothing is recorded. VERIFIED

19. How does incident memory work?

Incidents are represented as vectors and compared with native cosine similarity, equivalent to a FAISS flat inner-product index but without a native binary dependency. Searches are always limited to the incidents the user may see (department and organization). The Investigation panel shows the most similar past cases, how long ago they happened, and the responses that were effective. These feed Suggested Solutions. VERIFIED

F. The 5-minute response workflow

20. How does the 5-minute response workflow work?

For HIGH and CRITICAL incidents only, the deadline is detection time + 5 minutes. A "response required" notification goes to the SOC users who can see the incident, and the panel shows a live countdown. MEDIUM and LOW incidents always wait for an analyst. VERIFIED by unit tests and shown in the UI.

21. What happens when an employee acknowledges?

A clarification first: **in MIRQAB, acknowledgement is done by SOC staff** (Admin, Security Analyst, or the IT Technician of that department) in the dashboard, not by the affected employee. The backend has no employee-ownership model for incidents. When a SOC user clicks "Acknowledge & Investigate", or changes the incident status, the response is recorded. If this happens before the deadline, automated containment is permanently cancelled for that incident. If it happens after, it is recorded as a late response and never silently reverses an isolation. LIMITED with respect to employees.

22. What happens when the 5-minute deadline expires?

A background sweep takes one decision per incident under a database lock:

- If the incident is **simulated**, the "5-Minute Response Window" **policy is disabled**, or **no endpoint-control provider** is configured, the result is recorded as "automated containment not attempted" with the reason.
- Otherwise a PENDING `ISOLATE_DEVICE` action is saved and the real provider is called. The same record becomes SUCCESS or FAILED from the real result.

In both cases a "containment result" notification and an audit entry are written. No AI is consulted. LIMITED: in development, automated attempts were recorded as FAILED (no reachable endpoint), and a successful automated isolation on a live agent has not been demonstrated.

23. How is Simulation Mode prevented from causing real isolation?

- Simulation events are tagged at ingestion with the source `SIMULATION`, and those incidents are **excluded from automated containment** (unit-tested).
- The evaluator demo hard-codes every endpoint-control setting (Wazuh and generic EDR) to empty, so the demo **cannot** isolate anything.
- Simulated incidents are clearly labelled "Simulation (Synthetic)" in the UI.

Limitation: *manual* isolation is not blocked for simulated incidents. An analyst can still request it, after the confirmation dialog, for the device the simulation targeted. That remains an explicit human decision. VERIFIED for automation · LIMITED for manual actions.

G. Status

24. What is verified?

Authentication and sessions, RBAC and department scoping (18/18 live tests), organization scoping (unit tests), input validation, rate limiting, realtime security, audit integrity, detection, correlation, MITRE mapping, IOC/IOA extraction, incident memory, Suggested Solutions, the 5-minute response window logic, simulation exclusion, notifications for SOC staff, case and weekly reports, the Wazuh and Suricata ingestion paths, and device isolation **in the lab**. 421 backend tests pass, and all three applications type-check cleanly (27 Sep 2026). The complete evaluator demo was also run end-to-end from the packaged source, and all 48 checks passed.

25. What is limited?

Automated containment success on a live agent (not shown), isolation beyond the lab, MITRE coverage (12 techniques), risk "predictions" (statistics, not ML), notifications (SOC staff only), the Employee Desktop app (partial mock data), Arabic translation (partial), and the evaluator demo (not run on a separate clean machine).

26. What is not deployed?

MIRQAB as a whole: it runs locally in Docker, with no public domain or CA-issued TLS certificate. The self-hosted AI model: none deployed. External AI: not used at runtime.

27. What are the current limitations?

1. **Not deployed to production.** MIRQAB runs locally in Docker on the development machine. It has no public domain, and TLS uses a self-signed development certificate.
2. **No runtime AI model.** Classification, MITRE mapping, risk estimates and recommendations are deterministic and rule-based. The self-hosted AI provider is implemented but **not verified**: no model has been deployed. External AI (Claude) is disabled by default and is never used in the demo.
3. **Device isolation was verified only in a lab.** 2 of 2 successful end-to-end isolations used a containerized Linux safe-test agent. There are no tests on physical employee devices, the Windows script is not verified, and releasing an isolated device is not implemented in the application.
4. **Automated containment has not been shown to succeed live.** When the 5-minute window expires with no response, MIRQAB records an isolation request. In the development environment those attempts were recorded as **FAILED**, because no reachable endpoint existed behind the device.
5. **Wazuh version is BLOCKED.** The upstream 4.14.7 image was still a release-candidate build when checked. The lab ran that build.
6. **Wazuh Manager → MIRQAB forwarding script not verified.** The ingestion endpoint was verified with Wazuh-format payloads, but the Manager-side script was never run. MIRQAB does **not** read from the Wazuh Indexer.
7. **Limited detection coverage.** 12 curated MITRE ATT&CK techniques. Events that match no rule stay `UNCLASSIFIED`. For example, the dataset notes report all 6 PcapMonkey network events landing as UNCLASSIFIED / LOW.
8. **Notifications target SOC staff, not individual employees.** The Employee Desktop app partly uses clearly-marked mock data.
9. **Partial Arabic translation** in some incident-panel labels.
10. **No load testing**, and no live multi-organization test.
11. **No automated backup or disaster-recovery tooling.** Backups are manual (`pg_dump`).

12. **Demo setup not run on a clean machine.** The full evaluator demo was run end-to-end from the packaged source (48 of 48 checks passed), but only on the development machine, where Docker and base images were already present.
13. **Security review dates.** The 18-phase security review was completed on 6–8 Sep 2026. Features added later (the reworked 5-minute response window, Suggested Solutions, the evaluator demo) are covered by the current unit tests but have not had a dedicated security review.

28. What is the future roadmap?

All items below are PLANNED. None of them is built.

1. Deploy and evaluate a self-hosted model on suitable hardware.
2. Validate isolation on physical Windows and Linux devices, and add "release isolation".
3. Move to a GA Wazuh release and run the Manager integration end-to-end.
4. Production deployment: real domain and TLS, automated backups, disaster recovery, load testing.
5. Wider detection coverage, full Arabic translation, and employee-level notifications.
6. A dedicated security review of the features added after 8 September 2026.